

Authorization

Section Review

Authorization

- **Authorization** is the act of verifying that a user has permission to take an action.
- There are multiple approaches/strategies for authorization (roles, scopes, etc).

Role-Based Access Control (RBAC)

- Role-based access control (RBAC) is an authorization approach that grants permissions based on a user's role.
- Ex: A super admin role may have permissions that a regular user does not. Or a subscriber role may have permissions that a viewer role does not.

RBAC in FastAPI

- FastAPI's design revolves around route handlers/routers reusing dependencies.
- We extracted a **RoleRequired** class that checked whether the current user's role matched the required role for a given route.
- The **`__call__`** magic method enables an object to support the call syntax () so it is compatible with **Depends**.

Scopes

- A **scope** is a permission to take an action on a resource.
- The OAuth2 standard uses plain strings like **read:users** as scopes.
- A system has to assign scopes to users. There are multiple technical solutions (role-based, manual assignment, etc).

The Security Dependency

- Define a dependency function that raises an exception if a user does not have the scopes/permissions to take an action.
- Use **Security** for a router/route dependency (or as a parameter) and pass in the list of scopes to verify.
- FastAPI will run the route handler only if there are no raised exceptions.

Roles and Scopes

- Roles and scopes are not either-or options.
- Roles can provide a standard set of permissions.
- Scopes can provide a specialized set of resource permissions.
- Some routes/routers can use roles, others can use scopes, others can use both, etc.